AI POLICY PACK (5 POLICIES)

ENTERPRISE AI ASSURANCE & GOVERNANCE FRAMEWORK

Control Framework §4
System of Record: *AI Incident & Assurance Register*

Entity Name:	**[Company / Entity Name]**	**Version:**	**v1.0 (Standard)**
Approved By:	**[AI Owner / Chief Risk Officer]**	**Effective Date:**	**[DD / MM / YYYY]**
Accountable Exec:	**[Accountable Executive]**	**Review Cycle:**	**Annual / Triggered**

OPERATIONAL MANDATE: This policy instrument governs all employee, contractor, and agent interactions with Artificial Intelligence systems. Every deployed tool, incident, and decommission must be recorded in the official **AI Incident & Assurance Register**.

SECTION 1 — ACCEPTABLE AI USE POLICY

1. PURPOSE & SCOPE

This policy defines approved AI tools, permitted workplace applications, operational conditions, and mandatory governance parameters. It applies to all personnel, systems, and third-party contractors operating on behalf of the entity.

2. APPROVED TOOL CATEGORIES

Only AI tools listed in the enterprise *AI Incident & Assurance Register* are permitted for business workflows. Unlisted, unvetted consumer-grade tools ("Shadow AI") are strictly prohibited for processing enterprise resources.

3. PERMITTED & PROHIBITED USE CASES

- **Permitted:** Draft text synthesis, internal code generation, process automation, non-sensitive research, and preliminary data summarization under human supervision.
- **Prohibited:** Automated legal execution, unreviewed customer-facing advice, fully automated recruitment decisions, processing raw unencrypted PII, and bypassing security controls.

4. HUMAN-IN-THE-LOOP (HITL) REQUIREMENT

All AI-generated outputs must undergo human review, verification, and validation prior to external publication, customer distribution, or operational reliance. Autonomous execution without explicit Human-in-the-Loop oversight is strictly forbidden.

SECTION 2 — DATA HANDLING & AI POLICY

1. DATA CLASSIFICATION TIERING

Information processed via AI systems is governed by strict classification tiers:

Classification	Definition / Scope	AI Tool Eligibility
PUBLIC	Marketing materials, public press releases.	All Approved AI Tools
INTERNAL	Internal operating procedures, non-sensitive memos.	Approved Enterprise Tools Only
CONFIDENTIAL	Client PII, employee files, financial records.	Strictly Private Models (No Training)
RESTRICTED	Trade secrets, source code, credentials.	**PROHIBITED** (Unless On-Prem Isolated)

2. INGESTION & MODEL TRAINING RESTRICTIONS

Personnel must explicitly ensure that data opt-outs are active on all enterprise subscriptions. Company confidential information or personal data must **NEVER** be submitted to public models or used for public model retraining.

SECTION 3 — AI VENDOR ONBOARDING POLICY

1. NO STEALTH ONBOARDING

No AI software, browser plugin, API integration, or autonomous agent may be procured, installed, or integrated into business processes without undergoing formal vendor diligence and registry recording.

2. MANDATORY DUE DILIGENCE STEPS

Prior to contract execution or trial deployment, the designated AI Owner must complete the following mandatory onboarding controls:

- **Assigned Internal Owner:** Name a designated manager accountable for tool oversight and compliance.
- **Vendor Questionnaire:** Verify vendor data residency, data retention windows, sub-processor policies, and vulnerability disclosure mechanisms.
- **Security & Legal Review:** Confirm contractual assurances that customer data is isolated and excluded from model training corpus.
- **Register Logging:** Log the tool in the official *AI Incident & Assurance Register* prior to active operational use.

SECTION 4 — AI INCIDENT REPORTING POLICY

1. INCIDENT DEFINITION

An AI Incident is any unexpected or unapproved AI behavior that poses risks to enterprise data security, financial assets, legal compliance, or institutional reputation. Incidents include:

- Unauthorized exposure of Confidential or Restricted data via AI models.
- Autonomous agents acting outside established operational boundaries or guardrails.
- Vendor security breaches, prompt injection attacks, or discovery of unapproved AI tools ("Shadow AI").

2. 24-HOUR REPORTING MANDATE (NO-BLAME CULTURE)

Personnel must report suspected or confirmed AI incidents within **24 hours** of detection to the AI Owner and Security Team. Reporting is conducted under a strict **no-blame framework** to encourage rapid reporting, threat containment, and continuous remediation.

SECTION 5 — AI AGENT OFFBOARDING POLICY

1. DECOMMISSIONING PROTOCOL

When an AI agent, model, or third-party tool reaches end-of-life or contract termination, the following mandatory offboarding protocol must be executed and verified:

- **Data Retrieval & Export:** Complete export of all enterprise data, logs, and derived assets.
- **Deletion Confirmation:** Obtain written, enforceable confirmation of complete data deletion from vendor storage and backups.
- **Credential Revocation:** Revoke API keys, service accounts, and system access rights immediately.
- **Passport Closure:** Close the system's *Agent Passport* with formal decommissioning date stamp.
- **Register Update:** Update status to "Decommissioned" in the *AI Incident & Assurance Register*.

FORMAL POLICY ADOPTION & APPROVAL

By signing below, the designated executive and operational owners adopt these five AI Assurance policies as binding organizational standards for the specified entity.

AI Owner Signature & Date	**Accountable Executive Signature & Date**
Name: [_____]	Name: [_____]